

Università degli Studi di Salerno

Penetration Test Report

Il Caso Quaoar

Choaib Goumri (Mat. NF22500223) | Corso di PTEH | A.A. 2025/2026



UNIVERSITÀ DEGLI STUDI DI SALERNO
DIPARTIMENTO DI INFORMATICA

Indice

1	Executive Summary	2
2	Engagement Highlights	3
3	Vulnerability Report	4
3.1	Critical Vulnerabilities	4
3.2	High Vulnerabilities	4
3.3	Medium Vulnerabilities	5
3.4	Low Vulnerabilities	5
4	Remediation Report	6
4.1	Critical Remediation	6
4.2	High Remediation	6
4.3	Medium Remediation	7
4.4	Low Remediation	7
5	Findings Summary	8
6	Detailed Summary	11
6.1	Critical Vulnerabilities	11
6.2	High Vulnerabilities	12
6.3	Medium Vulnerabilities	13
6.4	Low Vulnerabilities	14
7	Bibliografia e Sitografia	15

Capitolo 1

Executive Summary

Il presente documento riassume i risultati del penetration test condotto sulla macchina virtuale **Quaoar**, con l'obiettivo di valutare il livello di sicurezza del sistema e identificare eventuali vulnerabilità sfruttabili da un attaccante.

L'attività è stata svolta adottando una metodologia *Black Box*: non sono state fornite informazioni preliminari sulla macchina target, simulando il comportamento di un attaccante esterno con accesso unicamente alla rete in cui il sistema era collocato.

L'analisi ha messo in evidenza vulnerabilità critiche a livello applicativo e sistemistico. In particolare, l'esposizione del *Theme Editor* di WordPress, assieme alla presenza di credenziali deboli e al riutilizzo della password di amministrazione del sistema operativo, ha permesso un'immediata compromissione della macchina target fino all'ottenimento dei privilegi **root**.

Ulteriori vulnerabilità di tipo *High*, *Medium* e *Low* hanno contribuito ad aumentare significativamente la superficie d'attacco, dimostrando come configurazioni errate e software obsoleto possano facilitare una compromissione completa del sistema.

Nel complesso, il livello di sicurezza della macchina può essere valutato come **basso**, mentre il rischio di compromissione effettiva risulta **elevato**.

Nelle sezioni successive sono presentati in dettaglio:

- le vulnerabilità individuate;
- l'analisi del rischio associato;
- le contromisure raccomandate;
- la classificazione completa con tabelle e grafici riassuntivi.

Capitolo 2

Engagement Highlights

Questa sezione descrive il contesto operativo e le regole d'ingaggio stabilite per lo svolgimento del penetration test. Poiché l'attività è stata condotta in ambiente accademico e non in un contesto aziendale reale, è stato simulato un accordo formale con una società fittizia allo scopo di riprodurre fedelmente la documentazione tipica di un penetration test professionale.

È stato quindi redatto e “firmato” un **Non-Disclosure Agreement (NDA)**, attraverso il quale l'azienda richiedente concede l'autorizzazione all'esecuzione del test, garantendo tuttavia la riservatezza delle informazioni acquisite durante l'analisi.

L'attività è stata svolta nel rispetto delle seguenti regole di ingaggio:

- il test è stato condotto sulla macchina **Quaoar** nella sua interezza;
- è stato autorizzato l'utilizzo di tutte le tecniche offensive tipiche del penetration testing, ad eccezione di attacchi *Denial of Service*;
- non è stato previsto l'utilizzo di tecniche di social engineering;
- è stato autorizzato l'ottenimento di privilegi amministrativi fino al livello **root**, se tecnicamente possibile;
- ogni passaggio rilevante è stato documentato in modo accurato.

Il test è stato eseguito utilizzando una macchina **Kali Linux** connessa alla stessa rete della macchina target, emulando così una condizione realistica di attaccante interno o con accesso alla medesima infrastruttura.

Capitolo 3

Vulnerability Report

Il presente capitolo sintetizza le vulnerabilità identificate durante il penetration test. Ogni vulnerabilità è classificata secondo il livello di rischio (Critical, High, Medium, Low) e descrive le condizioni che la rendono sfruttabile.

3.1 Critical Vulnerabilities

3.1 Remote Code Execution via WordPress Theme Editor

La presenza del Theme Editor attivo in WordPress ha consentito l'inserimento di codice arbitrario nei file PHP del tema (es. `header.php`), portando all'ottenimento di una reverse shell.

3.2 Privilege Escalation tramite password riutilizzata

La password presente nel file `config.php` coincide con la password dell'utente `root` del sistema operativo, permettendo un'escalation immediata.

3.2 High Vulnerabilities

3.3 WordPress Outdated (3.9.x)

Versione non supportata, soggetta a molteplici vulnerabilità note.

3.4 Credenziali deboli (admin/admin)

L'accesso al backend è stato possibile senza alcuna difficoltà grazie all'utilizzo di credenziali deboli.

3.5 Esposizione credenziali MySQL

Il file `/upload/config.php` espose in chiaro username e password del database.

3.3 Medium Vulnerabilities

3.6 XML-RPC Enabled

Endpoint utilizzabile per brute-force e attacchi di amplificazione.

3.7 Directory Listing Enabled

Alcune directory permettono di elencare contenuti sensibili.

3.8 Weak SSL/TLS Configuration

Cipher suite deboli e protocolli obsoleti rilevati da scanner.

3.9 Unnecessary Services Exposed

Servizi non necessari (es. POP3/IMAP) aumentano la superficie d'attacco.

3.4 Low Vulnerabilities

3.10 Server Information Disclosure

Banner HTTP rivelano versione di Apache e PHP.

3.11 ICMP Timestamp Response

Il sistema risponde a richieste ICMP con timestamp.

3.12 Weak SSH Algorithms

SSH presenta algoritmi considerati obsoleti.

3.13 Banner Disclosure Services

POP3/IMAP espongono banner informativi utili al fingerprinting.

Capitolo 4

Remediation Report

Questo capitolo elenca le misure correttive consigliate per mitigare le vulnerabilità identificate nel Capitolo 3.

4.1 Critical Remediation

4.1 Disabilitare il WordPress Theme Editor

Aggiungere nel file `wp-config.php`:

```
define('DISALLOW_FILE_EDIT', true);
```

4.2 Separazione delle credenziali

È necessario evitare il riutilizzo della stessa password tra:

- utenti di sistema;
- utenti del database;
- account amministrativi del CMS.

4.2 High Remediation

4.3 Aggiornamento di WordPress

Allineare CMS, plugin e tema alla versione più recente supportata.

4.4 Protezione del pannello di login

Implementare:

- autenticazione a più fattori (2FA);
- rate limiting;
- IP blocking.

4.5 Protezione del file config.php

Applicare restrizioni tramite Apache:

```
<Files config.php>  
    Require all denied  
</Files>
```

4.3 Medium Remediation

4.6 Disabilitare XML-RPC

Da aggiungere nel tema o in un plugin:

```
add_filter('xmlrpc_enabled', '__return_false');
```

4.7 Disabilitare directory listing

Options -Indexes

4.8 Migliorare configurazione TLS/SSL

Rimuovere cipher deprecati e forzare l'uso di TLS 1.2+.

4.4 Low Remediation

4.9 Offuscare banner di sistema

Nascondere versioni Apache/PHP.

4.10 Limitare ICMP

Bloccare timestamp reply con firewall.

4.11 Hardening SSH

Aggiornare `sshd_config` per rimuovere algoritmi insicuri.

Capitolo 5

Findings Summary

Questa sezione presenta una sintesi delle vulnerabilità identificate durante il penetration test sulla macchina **Quaoar**. Le vulnerabilità sono state classificate in quattro categorie di rischio: **Critical**, **High**, **Medium** e **Low**.

La tabella seguente riepiloga tutti i finding rilevati, associati al rispettivo livello di severità.

ID	Vulnerability	Risk
F1	WordPress Theme Editor RCE	Critical
F2	Privilege Escalation tramite Password Reuse	Critical
F3	WordPress Outdated (3.9.x)	High
F4	Weak Credentials (admin/admin)	High
F5	MySQL Credentials Exposure	High
F6	XML-RPC Enabled	Medium
F7	Directory Listing Enabled	Medium
F8	Weak TLS/SSL Configuration	Medium
F9	Unnecessary Services Exposed	Medium
F10	Server Information Disclosure	Low
F11	ICMP Timestamp Response	Low
F12	Weak SSH Algorithms	Low
F13	Banner Disclosure Services	Low

Per fornire una rappresentazione visiva della distribuzione dei rischi, sono stati generati i grafici riportati nelle figure sottostanti.

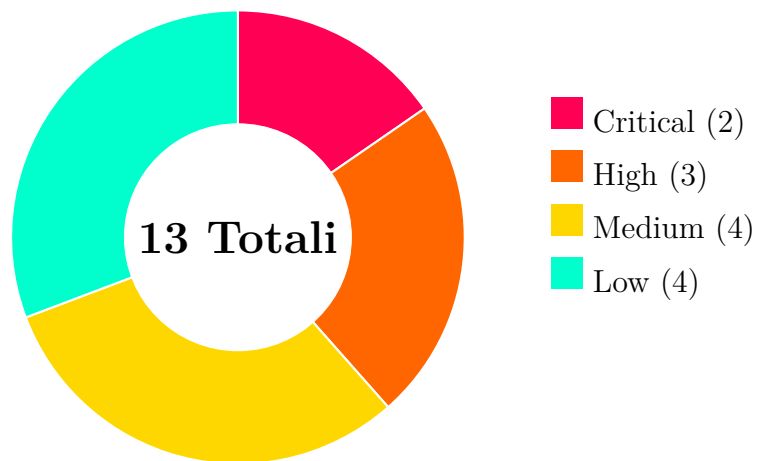


Figura 5.1: Distribuzione delle vulnerabilità per livello di rischio (Doughnut Chart).

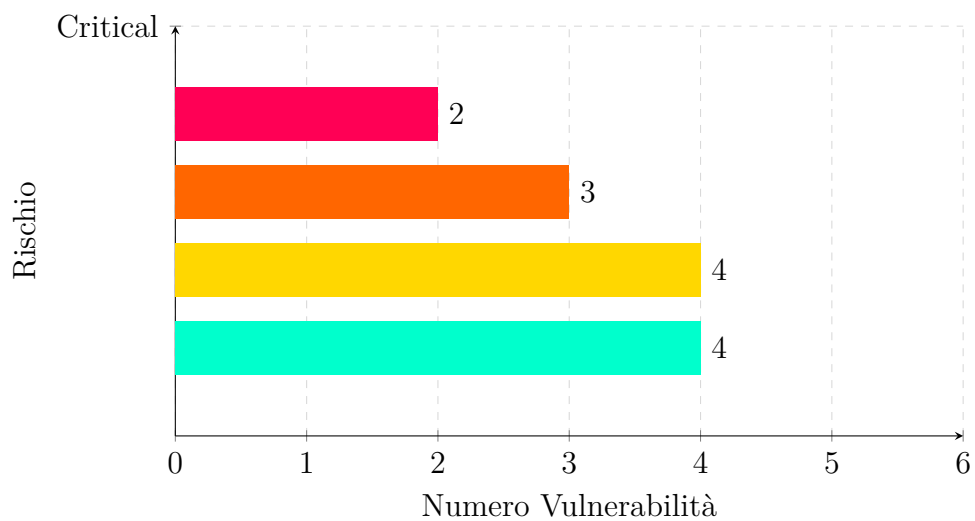


Figura 5.2: Ripartizione orizzontale delle vulnerabilità.

Il grafico evidenzia come la superficie di attacco della macchina Quaoar sia caratterizzata da un numero significativo di vulnerabilità ad alto impatto, con diversi punti di compromissione critica che consentono un controllo completo del sistema da parte di un attaccante.

Capitolo 6

Detailed Summary

Questo capitolo presenta una descrizione dettagliata di tutte le vulnerabilità riscontrate durante il penetration test condotto sulla macchina **Quaoar**. Per ciascun finding viene riportata una scheda tecnica strutturata contenente:

- descrizione della vulnerabilità;
- impatto sull'ambiente target;
- evidenze raccolte durante le attività offensive;
- raccomandazioni di mitigazione.

Le vulnerabilità sono organizzate in base alla loro severità: **Critical**, **High**, **Medium**, **Low** e **Info**.

6.1 Critical Vulnerabilities

CRITICAL VULNERABILITY	
Name	Remote Code Execution tramite WordPress Theme Editor
Description	La funzionalità <i>Theme Editor</i> di WordPress permette la modifica dei file PHP presenti all'interno del tema attivo. Un utente autenticato come amministratore può inserire codice arbitrario (reverse shell).
Impact	Compromissione totale dell'applicazione web e possibilità di eseguire comandi arbitrari sulla macchina target.
Evidence	Modifica del file PHP del tema tramite pannello WordPress e attivazione della reverse shell tramite richiesta HTTP.
Recommendation	Disabilitare il Theme Editor aggiungendo <code>define('DISALLOW_FILE_EDIT', true);</code> in <code>wp-config.php</code> . Aggiornare il CMS.

CRITICAL VULNERABILITY	
Name	Privilege Escalation tramite Password Reuse
Description	La password presente nel file <code>config.php</code> del DB coincide con la password dell'utente di sistema <code>root</code> . Questo riutilizzo ha permesso un'escalation immediata partendo dall'accesso <code>www-data</code> .
Impact	Ottenimento dei privilegi <code>root</code> e controllo completo del sistema operativo.
Evidence	Comando eseguito dalla reverse shell: <code>su</code> con password <code>rootpassword!</code> .
Recommendation	Implementare una rigorosa separazione delle credenziali, utilizzare password uniche, complesse e applicare politiche di rotazione.

6.2 High Vulnerabilities

HIGH VULNERABILITY	
Name	WordPress Outdated (3.9.x)
Description	L'installazione WordPress individuata risulta obsoleta e non più supportata, esponendo la macchina a vulnerabilità note (CVE).
Impact	Aumento significativo della superficie d'attacco, con rischio di compromissione remota.
Evidence	WPScan ha identificato la versione 3.9.x come end-of-life.
Recommendation	Aggiornare il CMS e tutte le sue componenti alla versione più recente.

HIGH VULNERABILITY	
Name	Weak Credentials (admin/admin)
Description	L'account amministrativo di WordPress utilizza credenziali estremamente deboli.
Impact	Accesso completo al backend amministrativo con possibilità di controllare tutta l'applicazione.
Evidence	Autenticazione avvenuta correttamente al primo tentativo.
Recommendation	Applicare una password robusta e introdurre 2FA.

HIGH VULNERABILITY	
Name	MySQL Credentials Exposure
Description	Il file di configurazione era accessibile e conteneva le credenziali del database in chiaro.
Impact	Accesso non autorizzato al database, potenziale escalation.
Evidence	Variabili <code>\$db_user="root"</code> e <code>\$db_pass="rootpassword!"</code> .
Recommendation	Proteggere i file sensibili tramite permessi più restrittivi.

6.3 Medium Vulnerabilities

MEDIUM VULNERABILITY	
Name	XML-RPC Enabled
Description	L'endpoint <code>xmlrpc.php</code> è attivo sull'istanza WordPress.
Impact	Utilizzabile per brute-force amplificati o attacchi pingback.
Recommendation	Disabilitare XML-RPC quando non strettamente necessario all'applicazione.

MEDIUM VULNERABILITY	
Name	Directory Listing Enabled
Description	Alcune directory del server mostrano pubblicamente la lista dei file interni.
Impact	Raccolta di informazioni sensibili utili per fasi successive.
Recommendation	Disattivare il directory indexing tramite direttiva <code>Options -Indexes</code> in Apache.

6.4 Low Vulnerabilities

LOW VULNERABILITY	
Name	Server Information Disclosure
Description	Il server rivela informazioni su Apache e PHP direttamente nei banner HTTP.
Impact	Possibilità per un attaccante di eseguire un fingerprinting accurato e cercare exploit mirati.
Recommendation	Offuscare i banner nelle configurazioni web per minimizzare le informazioni esposte.

Capitolo 7

Bibliografia e Sitografia

Di seguito sono riportate le principali fonti e risorse pubbliche, documentazioni ufficiali e repository che sono state utilizzate per la conduzione delle attività di penetration testing e per l'analisi delle vulnerabilità sulla macchina *Quaoar*.

Documentazione dei Tool e Framework

- **Kali Linux:** Penetration Testing and Ethical Hacking Linux Distribution.
<https://www.kali.org/>
- **Nmap:** Free Security Scanner, Port Scanner, & Network Exploration Tool.
<https://nmap.org/>
- **WPScan:** Black box WordPress vulnerability scanner.
<https://wpscan.com/>
- **Dirb / Gobuster:** Strumenti per il directory e file brute-forcing.
<https://github.com/OJ/gobuster>

Risorse di Exploitation

- **PentestMonkey - PHP Reverse Shell:** Template per reverse shell in PHP.
<https://pentestmonkey.net/tools/web-shells/php-reverse-shell>
- **GTFOBins:** Lista curata di binari Unix utilizzabili per aggirare le restrizioni di sicurezza locali.
<https://gtfobins.github.io/>
- **7h3rAm Writeups:** Repository GitHub documentativo per l'RCE via WordPress Theme Editor.
<https://github.com/7h3rAm/writeups/tree/master/vulnhub.quaoar>

Guide Metodologiche

- **OWASP Testing Guide (WSTG)**: Standard de facto per il penetration testing web.
<https://owasp.org/www-project-web-security-testing-guide/>
- **PTES (Penetration Testing Execution Standard)**: Standard di riferimento per le fasi di esecuzione del penetration test.
<http://www.pentest-standard.org/>